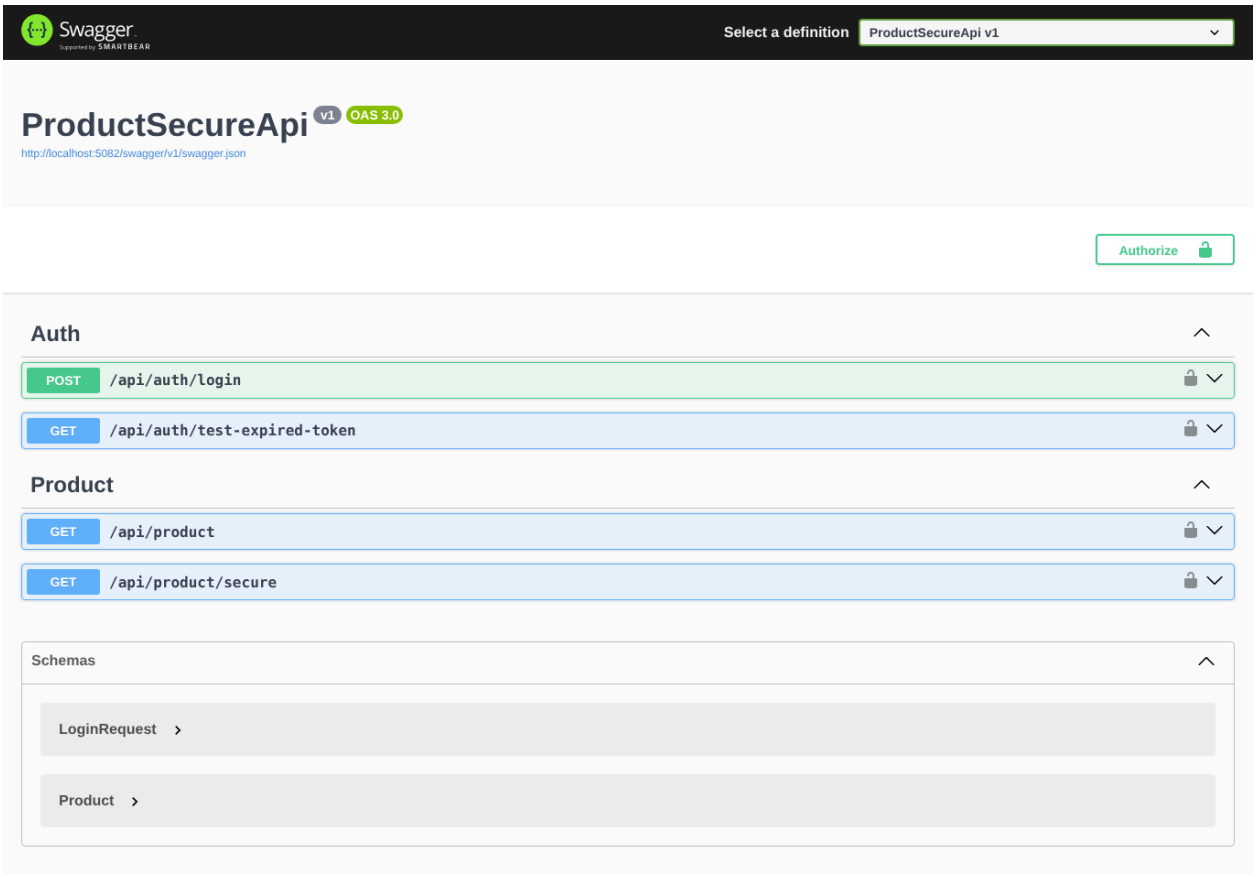
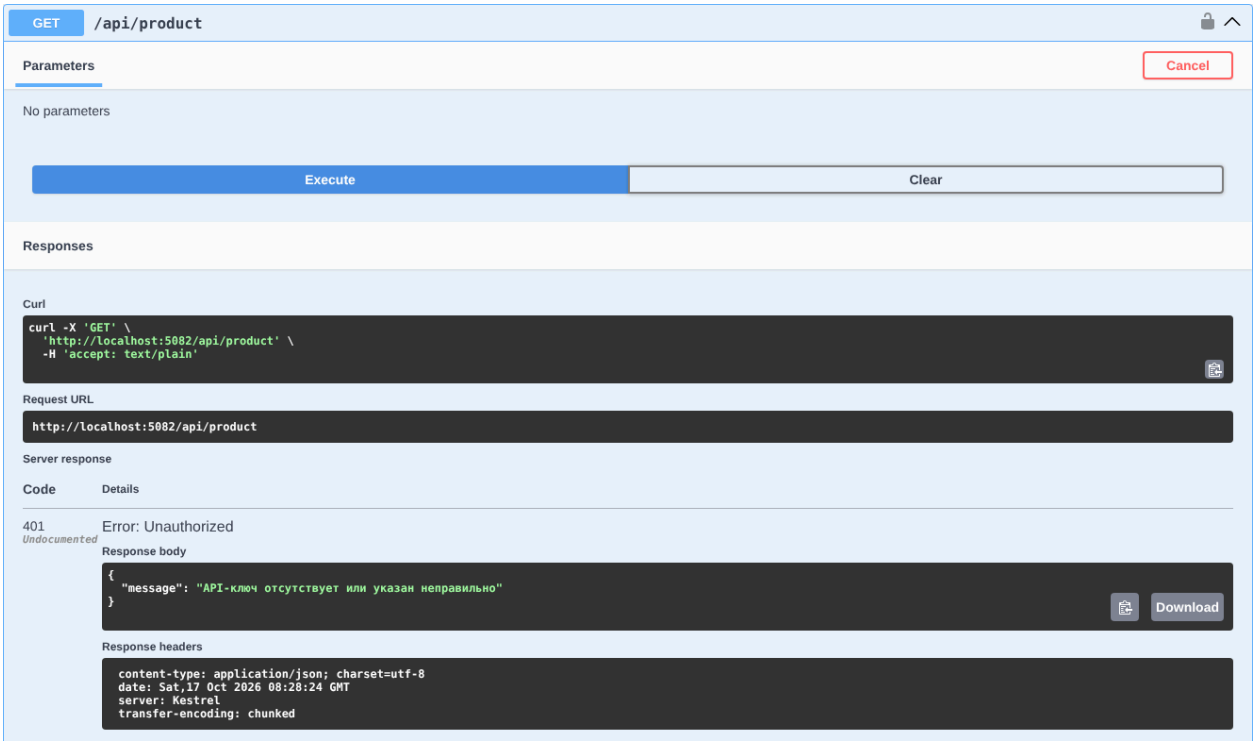
Swagger UI проекта



GET /api/product защита API-ключом



GET /api/product без API-ключа 401 Unauthorized

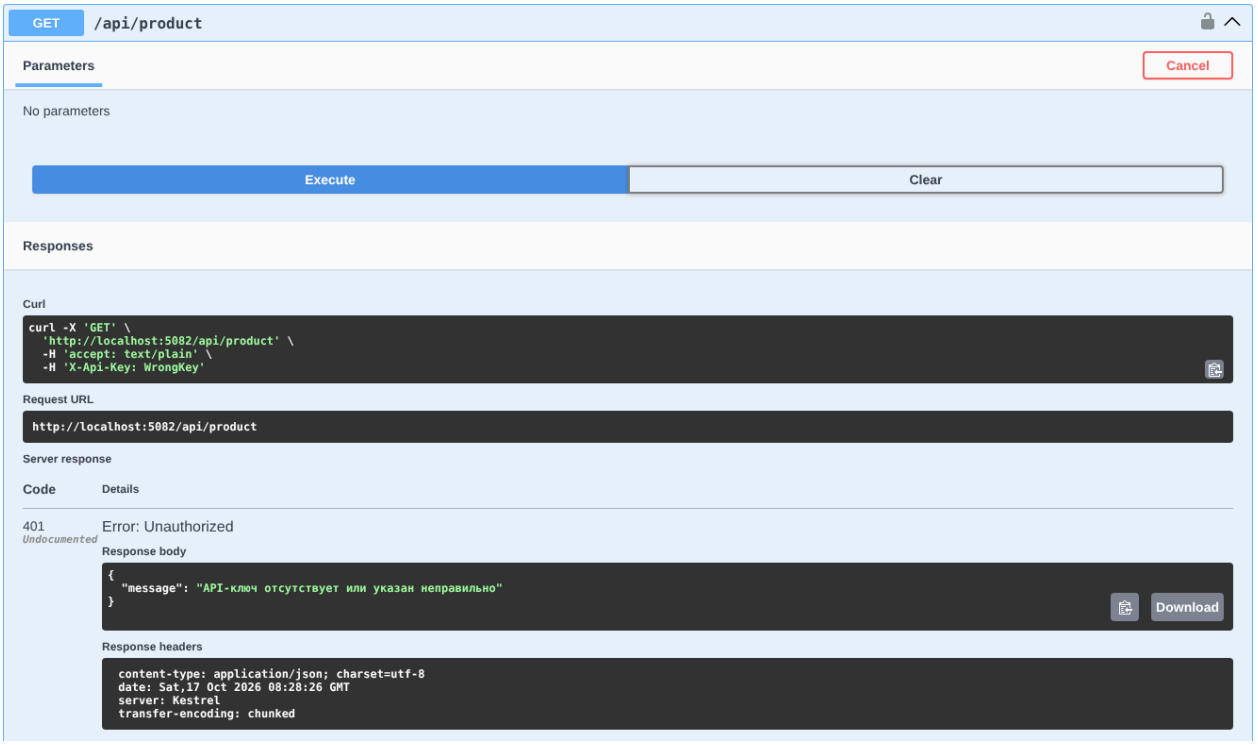
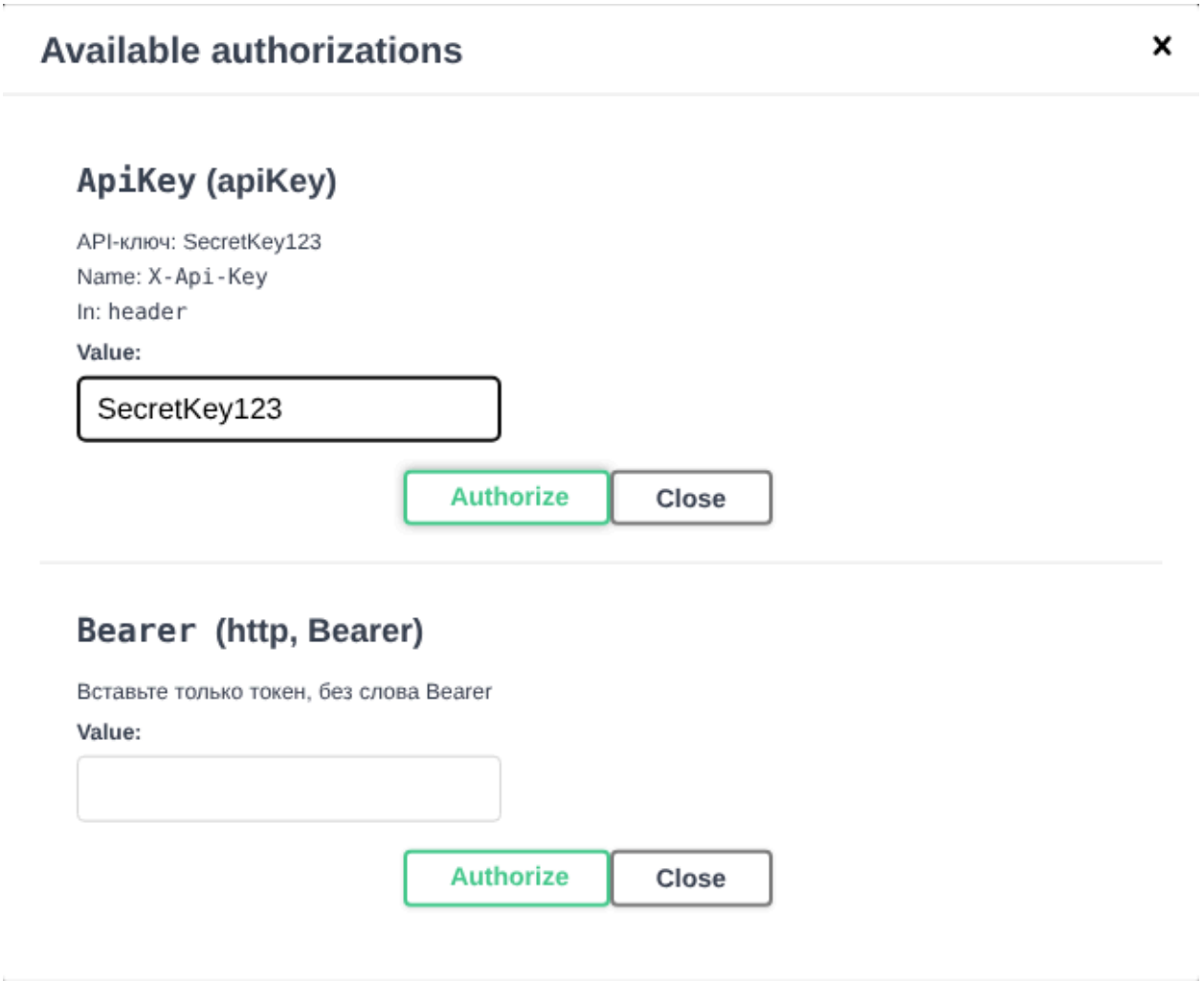
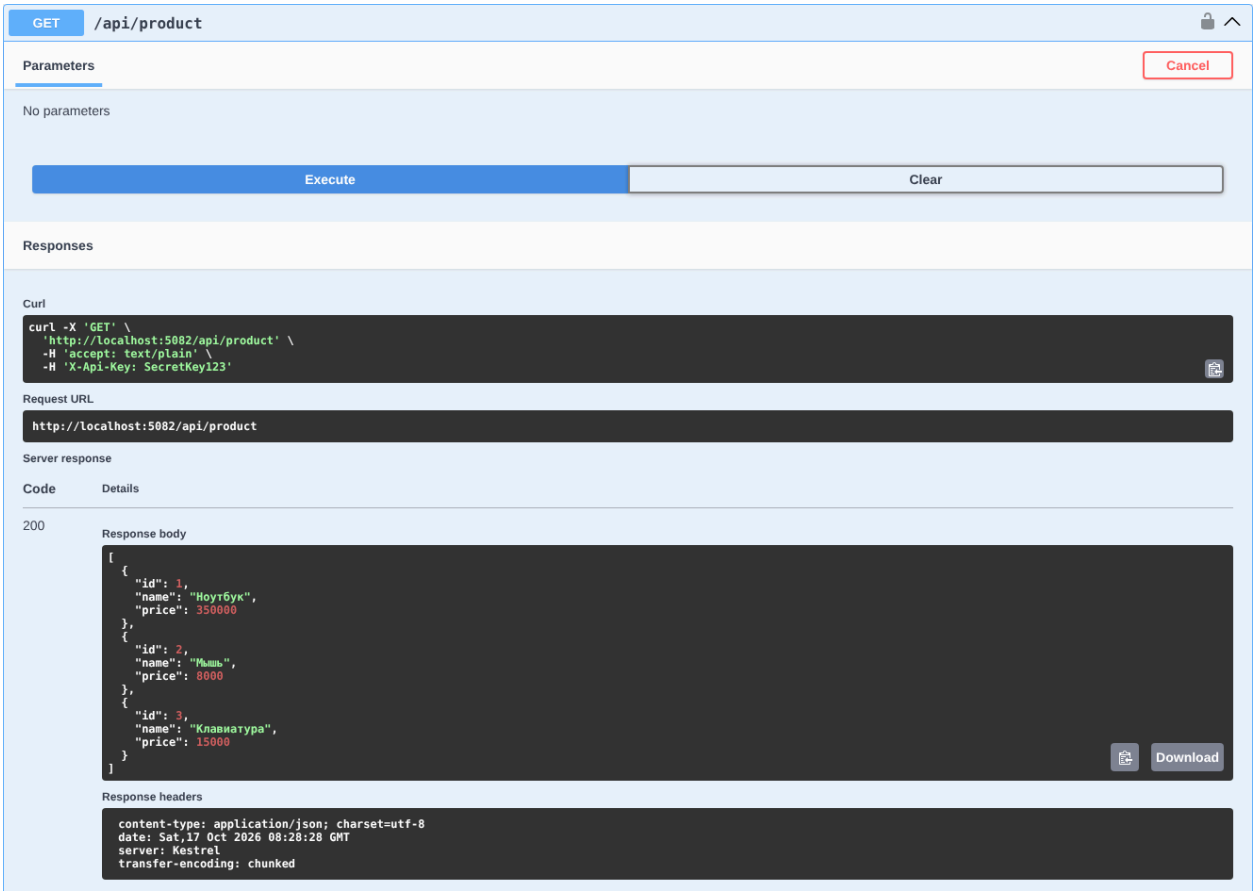


Рисунок GET /api/product с неверным ключом X-Api-Key: WrongKey 401 Unauthorized

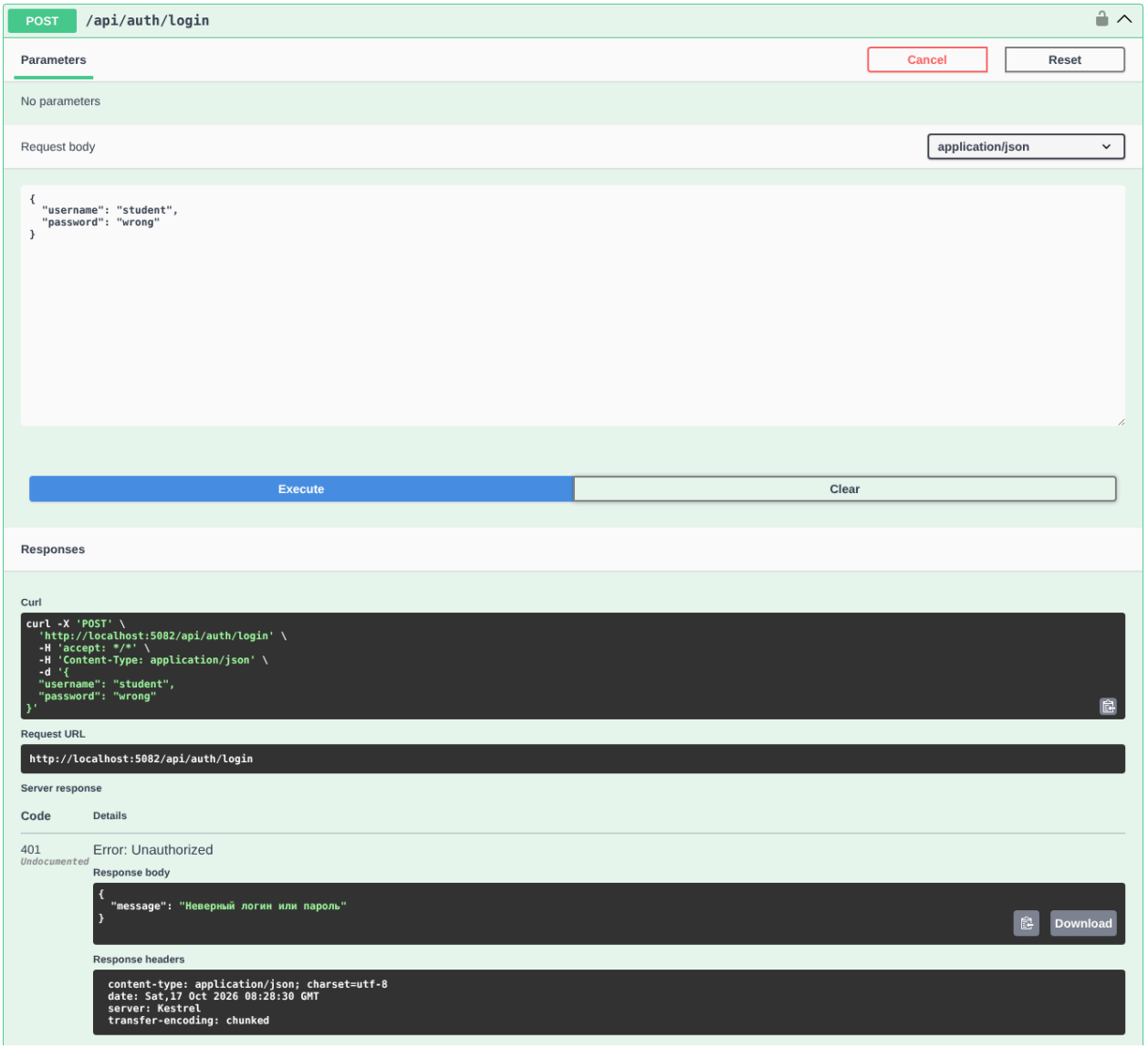


Окно Authorize: ввод API-ключа SecretKey123 в заголовок X-Api-Key

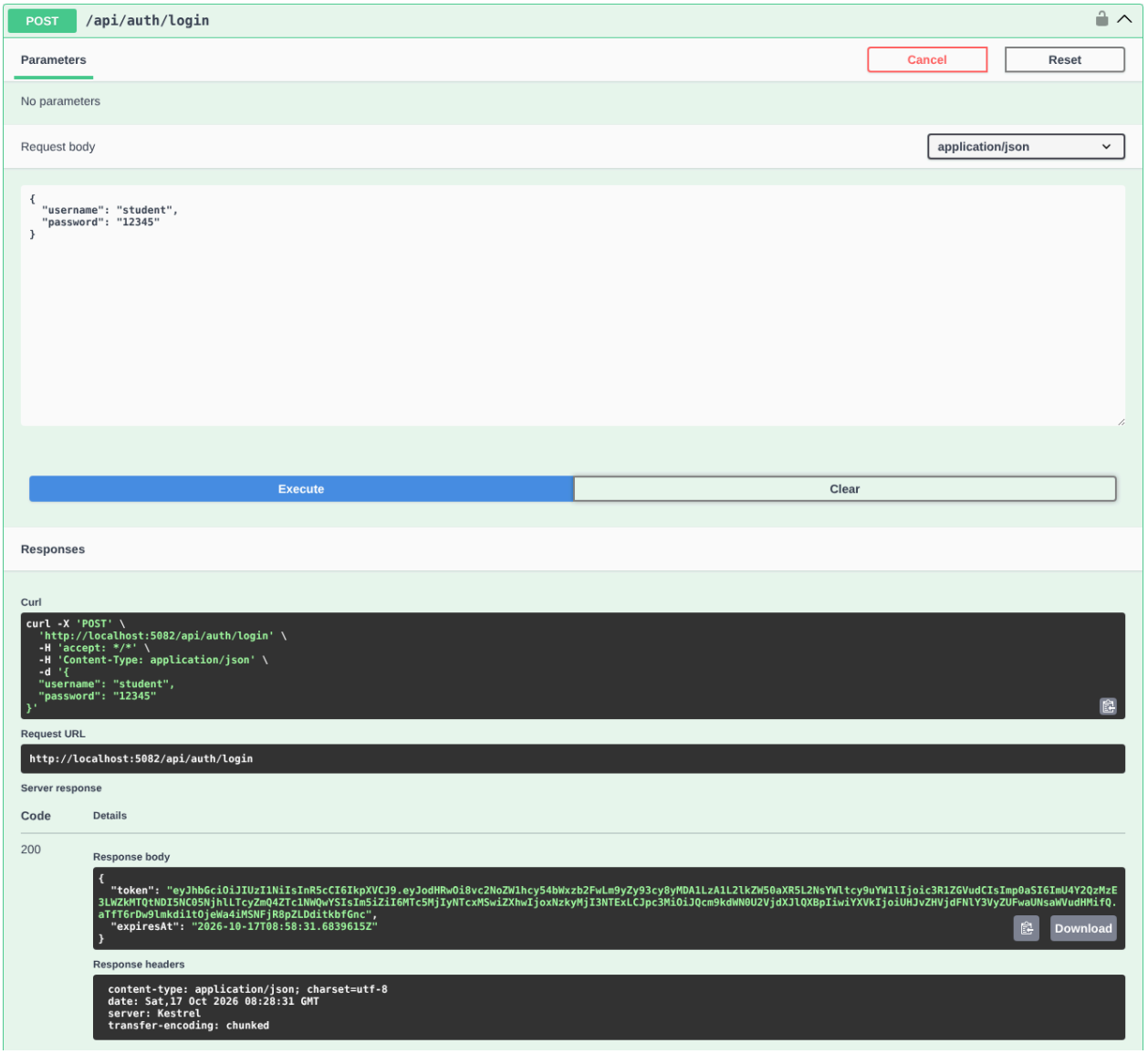


GET /api/product с правильным ключом X-Api-Key: SecretKey123 200 OK, список товаров

POST /api/auth/login получение JWT

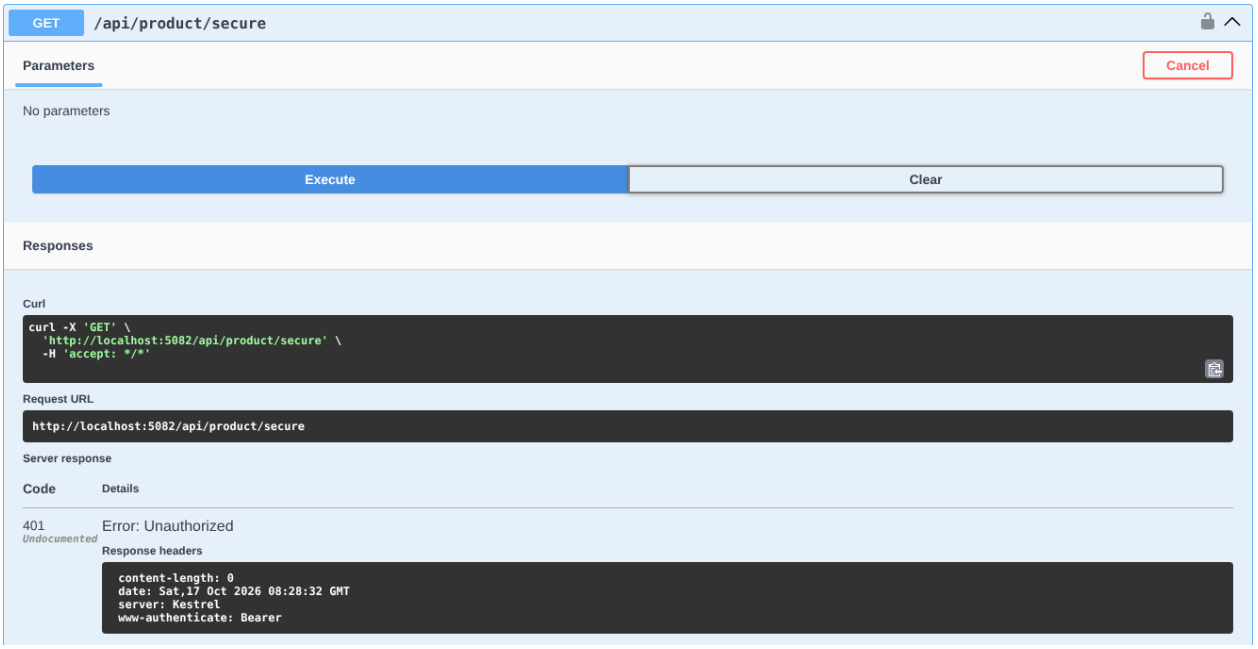


POST /api/auth/login с неверным паролем 401 Unauthorized

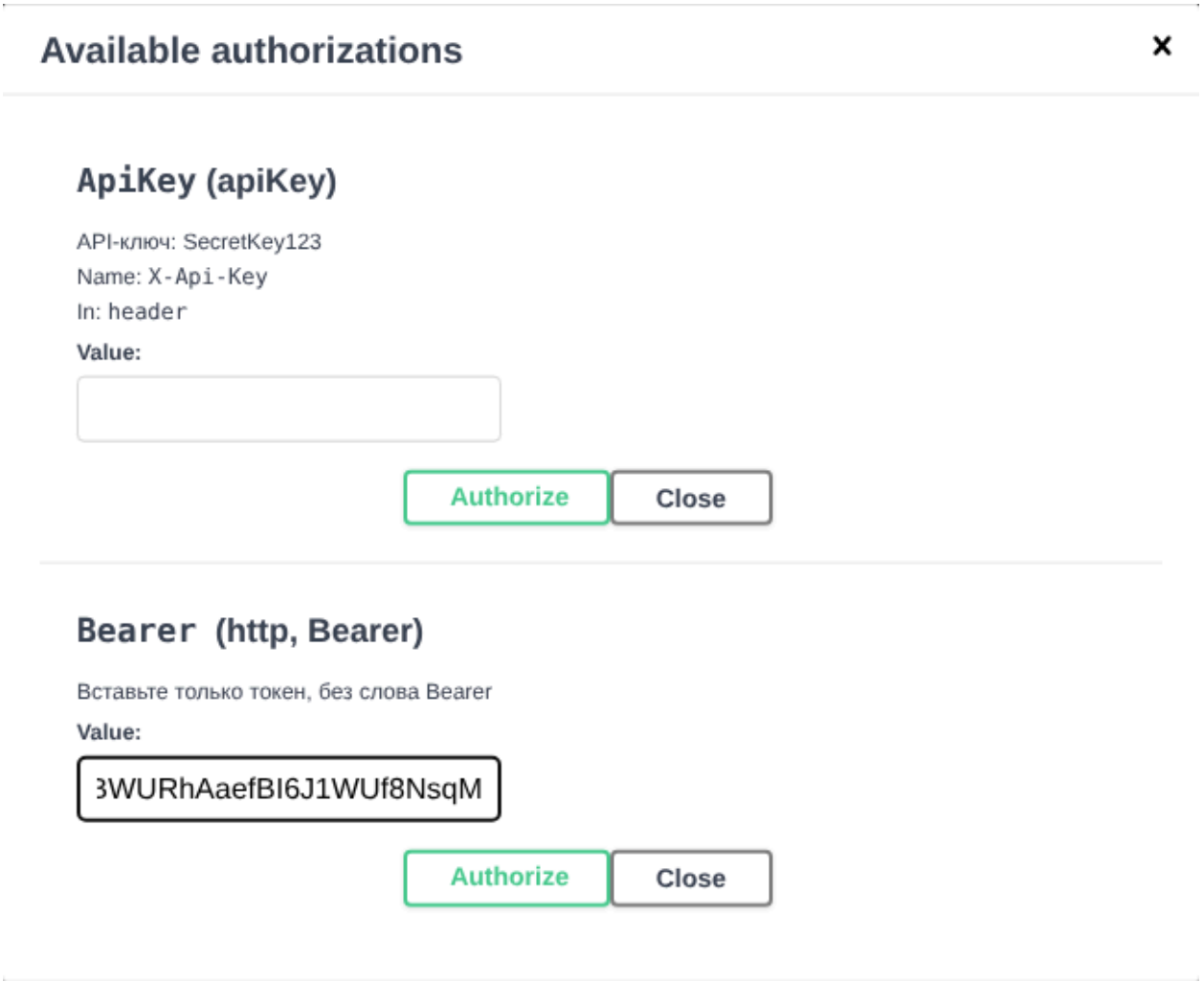


POST /api/auth/login (student / 12345) 200 OK, получен JWT-токен

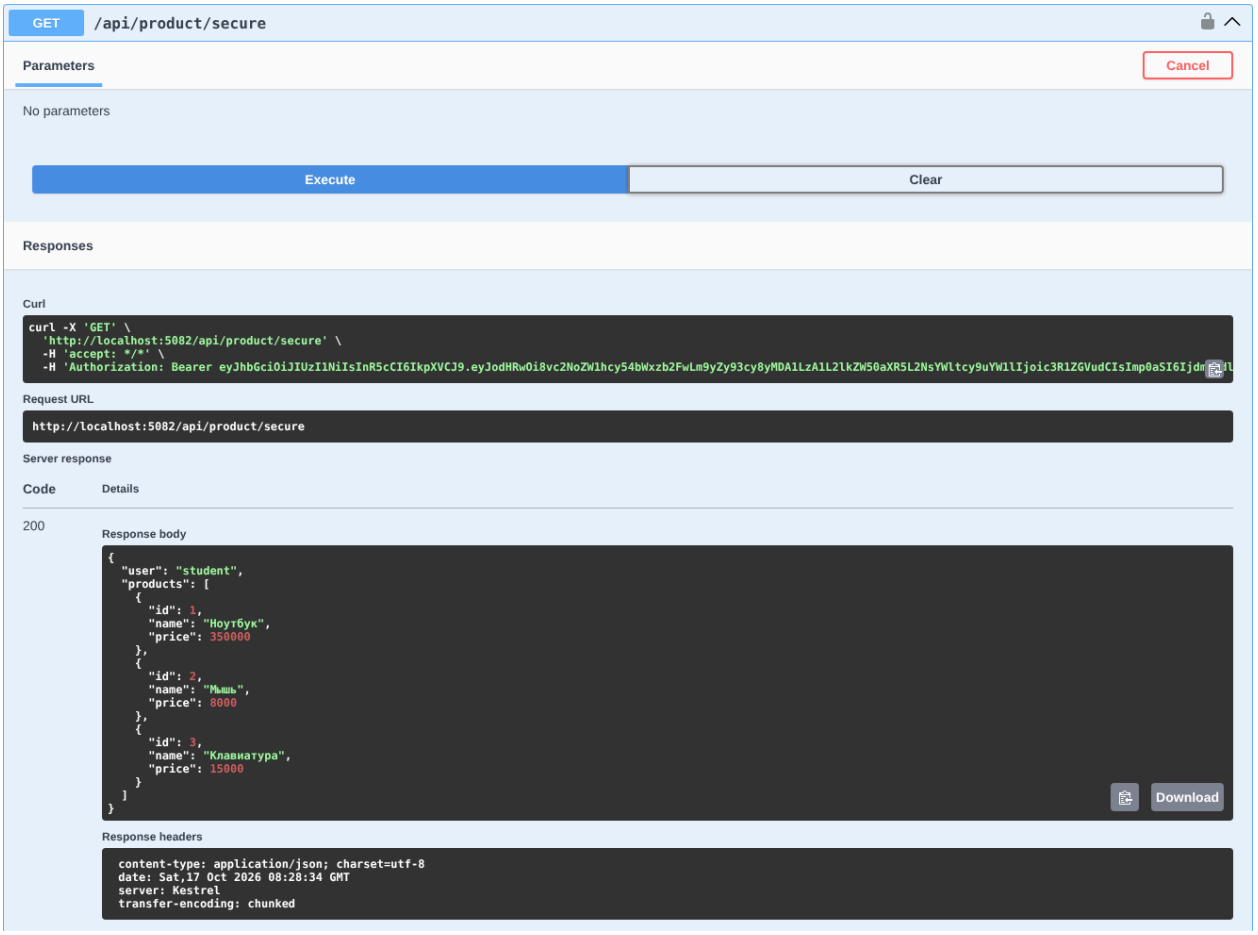
GET /api/product/secure защита JWT



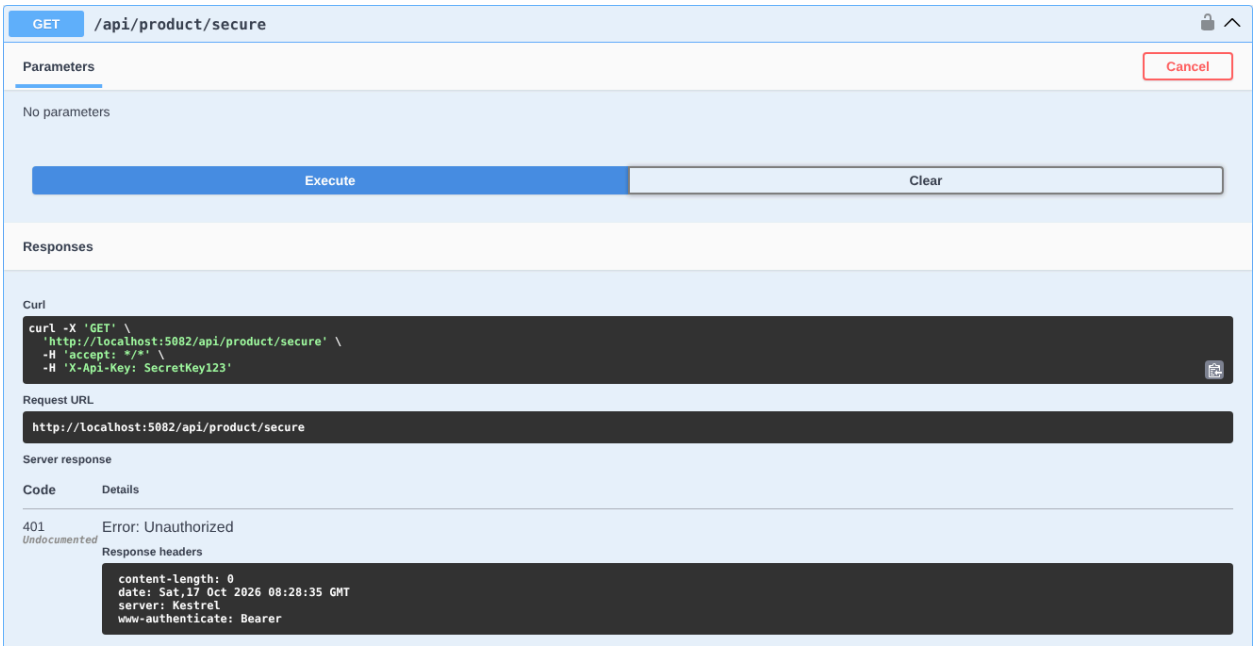
GET /api/product/secure без токена 401 Unauthorized



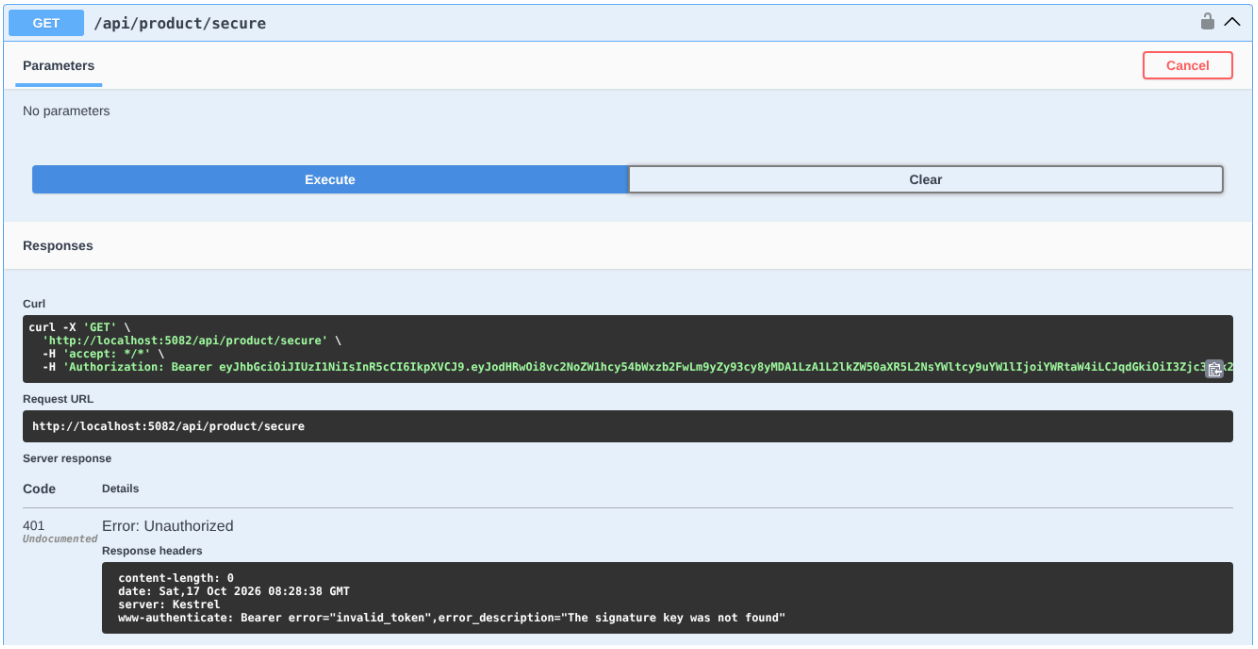
Окно Authorize: ввод JWT-токена для схемы Bearer



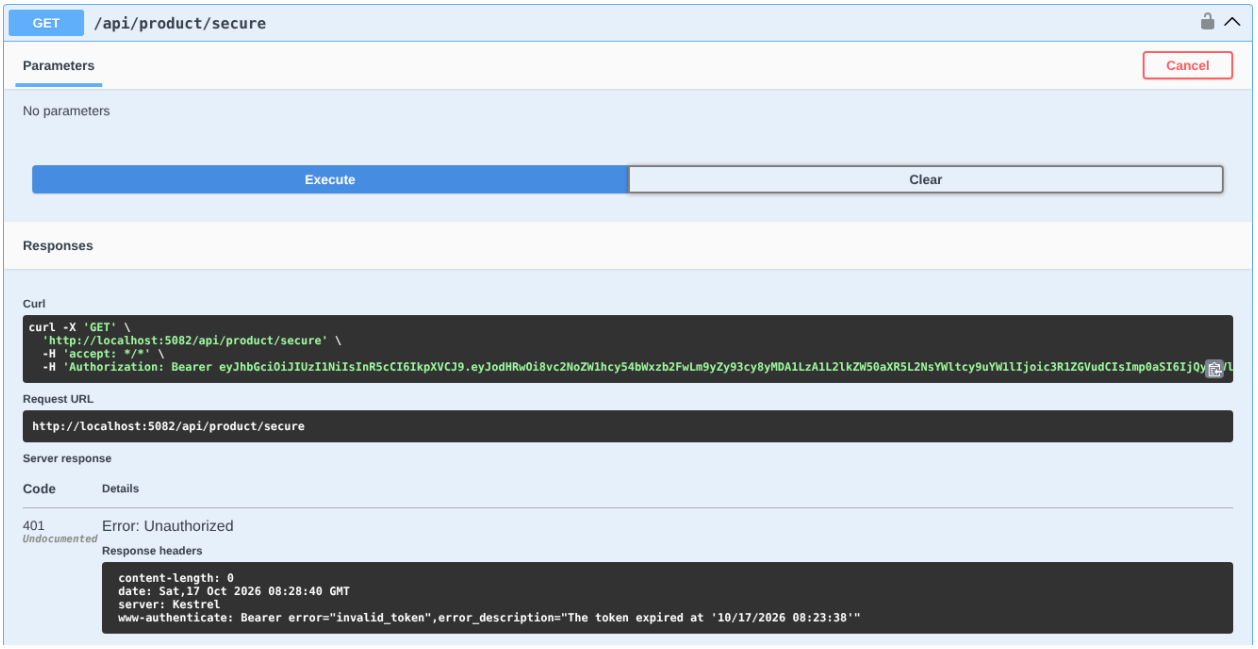
GET /api/product/secure с Authorization: Bearer <token> 200 OK, user: student



GET /api/product/secure только с API-ключом, без JWT 401 Unauthorized

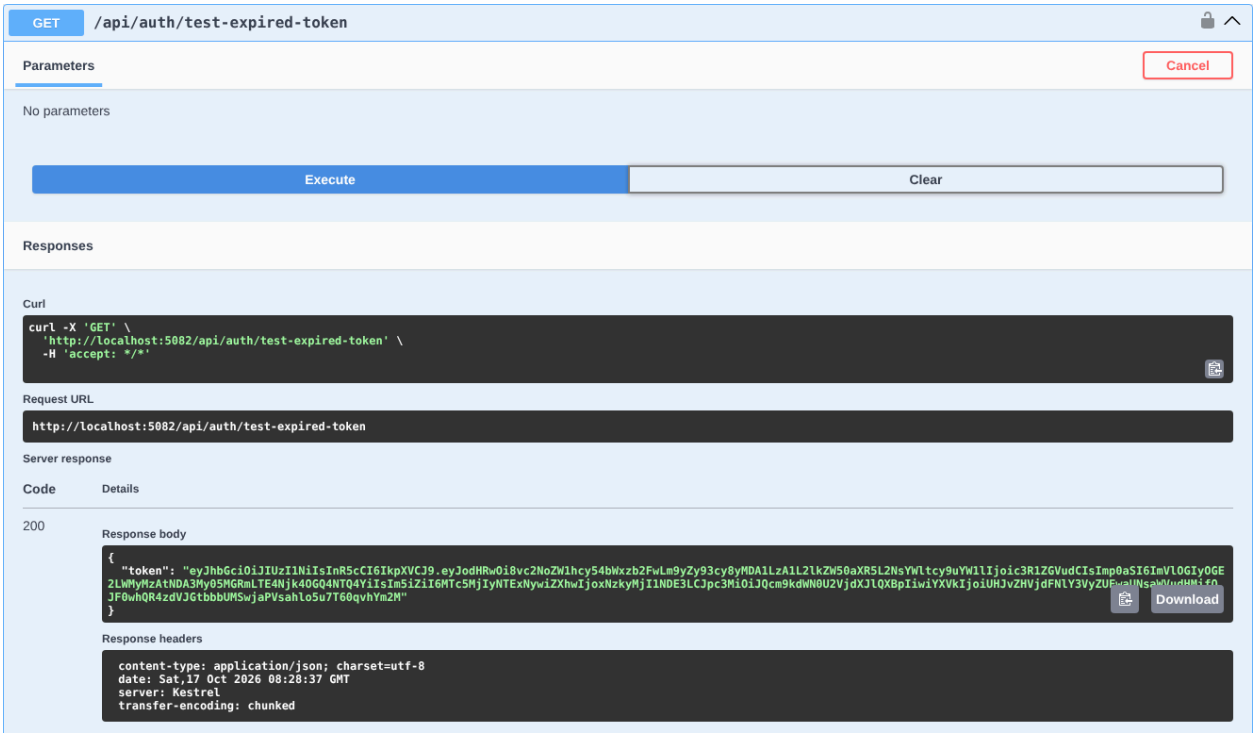


GET /api/product/secure с изменённым токеном (name: student - admin) 401, invalid_token



GET /api/product/secure с просроченным токеном 401, The token expired

GET /api/auth/test-expired-token тестовый просроченный токен



GET /api/auth/test-expired-token 200 OK, выдан просроченный токен (только Development)

Контрольные вопросы

Какой HTTP-код возвращается при вызове метода с [Authorize] без JWT и почему?

401 Unauthorized. Middleware аутентификации не нашёл заголовок `Authorization`, и пользователь остался анонимным. Middleware авторизации видит атрибут `[Authorize]` и отвечает 401 с заголовком `WWW-Authenticate: Bearer`. Код 403 Forbidden возвращается, когда пользователь аутентифицирован, но ему не хватает прав (например, роли).

Чем API Key отличается от JWT?

API Key один общий бессрочный секрет. Он подтверждает, что клиент знает ключ, но не говорит, кто именно обращается. JWT выдаётся конкретному пользователю после проверки логина и пароля, содержит его данные (Claims), подписан ключом сервера и имеет ограниченный срок действия.

Из каких частей состоит JWT?

Из трёх частей в Base64Url, разделённых точками: `header.payload.signature`. Header алгоритм подписи (HS256). Payload Claims: имя, `iss`, `aud`, `exp`. Signature HMAC-SHA256 от первых двух частей на секретном ключе. Payload не зашифрован, а только подписан, поэтому секреты в нём хранить нельзя.

Почему изменённый токен отклоняется?

Сервер заново вычисляет подпись от header и payload своим ключом и сравнивает её с подписью в токене. После изменения любого символа подписи не совпадают, а подобрать правильную подпись без секретного ключа невозможно. Поэтому сервер отвечает 401.

Зачем ClockSkew = TimeSpan.Zero?

По умолчанию JwtBearer допускает расхождение часов в 5 минут и принимает токен ещё 5 минут после истечения срока. При нулевом ClockSkew истёкший токен отклоняется сразу, что и проверяется в задании

Почему UseAuthentication() должен стоять перед UseAuthorization()?

Аутентификация читает токен и заполняет `HttpContext.User`, а авторизация по этому пользователю решает, пускать ли к методу с `[Authorize]`. При обратном порядке пользователь на этапе авторизации всегда анонимный, и даже корректный токен даёт 401.